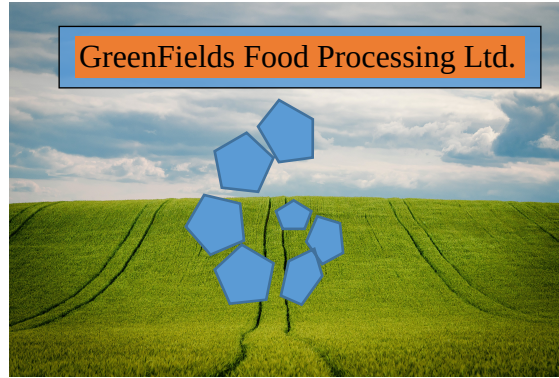




Security Improvement Plan

APRIL 2026

Approved by GreenFields Food Processing Ltd. Security Committee on
April 22nd 2026

Version V

INTERNAL WORKING DOCUMENT

TABLE OF CONTENTS

- 1. Security Maturity Assessment.....3
- 2. Top 10 Security Risks.....4
- 3. Priority Security Improvements5
 - a. Network Segmentation (Critical).....5
 - b. Multi-Factor Authentication (MFA).....5
 - c. Endpoint Detection & Response (EDR).....5
 - d. Security Awareness Training Program.....5
 - e. Backup Strategy Overhaul.....5
 - f. Privileged Access Management (PAM).....6
 - g. Formally Followed Security Policies & Procedures.....6
 - h. Patch Management Automation.....6
 - i. Incident Response Plan.....6
 - j. Third-Party Risk Management.....7
- 4. Implementation Roadmap8
 - a. Phase 1: Operational Goals (Months 0-6)8
 - b. Phase 2: Tactical Goals (Months 7-12)8
 - c. Phase 3: Strategic Goals (Months 13-18).....9
- 5. Estimated Budget Allocation (€80,000/year).....10
- 6. Metrics for Measuring Security Improvement (KPIs).....11

1. Security Maturity Assessment

Governance	Lack of: formal policies, risk assessment, protection of root access, expects greater reliance on digital systems because of expnading internationally
Risk Management	No formal risk assessment has ever been performed
Technical controls	No security monitoring, Patch management is inconsistent, No network segmentation currently implemented, Backup exists but is stored on the same network, Production network connected directly to corporate network
Staff & Training	Employees receive no security training; 3 people for whole of security in the org.
Incident Response (IR)	No formal IR plan, backups are vulnerable to same threats as production

Exposed:

- Single point of failure architecture (no network segmentation)
- Lack of defense-in-depth
- No visibility into security events
- High human factor risk (phishing susceptibility)
- Business continuity at risk (backup strategy is inadequate)

2. Top 10 Security Risks

#	Risk	Impact	Likelihood	Reasoning
1	Ransomware Attack	Critical	High	Industry target; supplier already compromised; no segmentation
2	Phishing/Social Engineering	High	Very High	Previous successful attack; no training
3	Insider Threat	High	Medium	Shared admin credentials; no access controls
4	Data Breach - Lost Device	High	Medium	Already occurred; no DLP or encryption
5	Network Compromise	Critical	High	Connected to corporate network; OT/IT convergence risk
6	Supply Chain Attack	High	Medium	Supplier already hit; interconnected systems (software components, APIs, other digital services)
7	Backup Failure/Corruption	Critical	High	Backups on same network; no “air-gap”
8	Unpatched Systems	High	High	Inconsistent patch management across 120+ endpoints
9	Privilege Escalation	High	Medium	Shared admin accounts; no “least privilege”
10	Regulatory Non-Compliance	Medium	High	GDPR, “food defense” and “food fraud” regulations/good practices violated

3. Priority Security Improvements

a. Network Segmentation (Critical)

What: Separate production, corporate, and guest networks using VLANs and firewall rules.

Why: Prevents lateral movement if corporate network is compromised. Protects production systems (OT) from IT threats. Critical for business continuity.

b. Multi-Factor Authentication (MFA)

What: Implement MFA for all remote access, email, and privileged accounts.

Why: Mitigates credential theft from phishing that **already occurred**. Reduces unauthorized access risk.

c. Endpoint Detection & Response (EDR)

What: Deploy EDR solution on all endpoints with centralized monitoring.

Why: Provides visibility into security events. Enables rapid threat detection and response. Addresses lack of monitoring.

d. Security Awareness Training Program

Description: Quarterly training for employees about dangers of phishing but instead of making them detect them, teach them to sandbox the links, etc. that click on.

Why: Human factor can be primary attack vector. Previous phishing success indicates vulnerability. Training as described would **prevent damage even** when employees would fail to detect phishing attempt.

e. Backup Strategy Overhaul

What: Implement “3-2-1 rule” for backups .

Why: Current backups are vulnerable to ransomware, and implementing the aforementioned rule would make RTO and RPO decrease in time.

f. Privileged Access Management (PAM)

What: Eliminate shared admin accounts; implement individual privileged access with passwords following good practices, and MFA (at least 3), including hardware option, or biometrics.

Why: Shared credentials lessen accountability and increase risk. PAM enables audit trails and reduces insider threat risk, or at least prevents insider threat actors from being detected.

g. Formally Followed Security Policies & Procedures

What: Develop and document security policies aligned with ISO 27001 framework (ISO/IEC 27001:2022).

Why: Provides foundation for ISMS. Accounts also for expectations from customers/business partners, and makes a company have higher value in sense of competitiveness in the market.

h. Patch Management Automation

What: Implement automated patch management of appropriate software components for all endpoints, and establish monthly patching for the rest of software component.

Why: Automation takes work from the already minimal IT team, and allows for ASAP patching of software components that would not break anything. The rest it patched and tested on a monthly basis. With current IT staff that is more than enough. When more IT personnel can work on it, **THIS NEEDS REVISION.**

i. Incident Response Plan

What: Develop and test IR plan with defined roles/responsibilities, and procedure.

Why: Reduces RTO and RPO. Ensures coordinated response. Required for regulatory compliance – DORA (The Digital Operational Resilience Act (Regulation (EU) 2022/2554)).

j. Third-Party Risk Management

What: Monitor, and test in a sandbox third-party software components, and require good practices, and recognized security standards during their DevSecOps cycle.

Why: Supplier already experienced ransomware. Supply chain attacks are common and listed in OWASP Top 10 2025.

4. Implementation Roadmap

a. Phase 1: Operational Goals (Months 0-6)

Month	Task	Lead By
0-2	Security policy framework development	Outsourced
0-2	MFA deployment for all remote/email access	Internal IT team
2-3	Network segmentation planning & pilot model	Outsourced
3-4	EDR deployment	Internal IT team
4-5	Backup strategy re-design & implementation	Internal IT team
5-6	Security awareness training launch	Internal IT team

Phase 1 Deliverables:

- Documenting Security policies.
- Proof of MFA being operational.
- Proof of EDR monitoring being active.
- First training cycle should be completed and documented.

b. Phase 2: Tactical Goals (Months 7-12)

Month	Task	Owner
7-8	Network segmentation completion	Outsourced
8-9	Implementation of PAM	Outsourced
9-10	Automation of patch management	Internal IT team
10-11	Incident Response Plan development & testing	Outsourced
11-12	Third-party risk assessment program	Internal IT team

Phase 2 Deliverables:

- Production network isolated
- Privileged access control documented
- Patch compliance >90%
- IR plan test report

c. Phase 3: Strategic Goals (Months 13-18)

Month	Task	Owner
13-14	Security metrics dashboard implementation	Internal IT team
14-15	ISO 27001 gap analysis & remediation	Outsourced
15-16	Advanced threat hunting capability	Outsourced
16-17	Security culture maturity assessment	Internal IT team
17-18	Comprehensive audit & certification preparation	Outsourced

Phase 3 Deliverables:

- Continuous monitoring dashboard
- ISO 27001 readiness documented proof
- Mature security culture establishment assessment report
- Audit-ready documentation stored properly (digital & print format, fireproof locker, off-site copy)

5. Estimated Budget Allocation (€80,000/year)

Category	Annual Budget	% of Total	Key Items
Security Tools	€35,000	44%	EDR licenses, MFA solution, PAM, backup storage
Outsourcing	€25,000	31%	Policy development, network design, IR plan, ISO preparation
Training & Awareness	€8,000	10%	Employee training platform, phishing incident resilience training
Infrastructure	€7,000	9%	Network hardware, firewall upgrades, backup hardware
Contingency	€5,000	6%	Emergency response, unexpected requirements

6. Metrics for Measuring Security Improvement (KPIs)

#	Metric	Target (18 months)	Measurement Method
1	Un-sandboxed Phishing Link Open Rate	<1% (from current unknown)	Simulated phishing campaigns quarterly
2	Patch Compliance Rate	>95% within 14 days of release	Automated patch management reporting
3	Mean Time to Detect (MTTD)	<1 hour	EDR and SIEM logging
4	Backup Success Rate	100% with monthly restore tests	Backup system logs and test records
5	Security Training Completion	100% of employees quarterly	Supervisor reports

———NOTE ON RESOURCES LIST———

I used Lumo AI from Proton (no idea what version but it is open sourced by default) for initial body of text and structure. Exemption would be title page that I did by following some advice from one pdf template from the internet. Then I reviewed most of the material and added/removed contents accordingly, using knowledge, acquired during first year of MSc, and quick internet searches. No specific resources are listed as this would be misleading/unfair.